Privacy Analysis

Individual Analysis - Jennifer Panula

AI Statement: I used ChatGPT to assist with coding, including helping utilize NLP and construct matrices, as well as discovering and extracting regulatory policy features as proxy variables. However, I reviewed and tweaked code and wrote this analysis. I also used Claude to help provide a more detailed analysis of how some of the companies conformed (or failed to conform) to some of the regulatory items.

Overview of Services Analyzed

The privacy policies in this analysis pertain to the below services. The agreed date may be an estimate by the user.

Service	Category	When Agreed	How agreed
Netflix	Entertainment	Oct-25	account signup
Discover Bank	Financial	Aug-18	account signup
OpenAI	Educational/professional tools	Apr-24	account signup
Meta	Social media	Aug-05	account signup
Microsoft	Educational/professional tools	Mar-23	account signup
Spotify	Entertainment	Aug-24	account signup
Uber	Retail/Other services	Feb-22	account signup
Robinhood	Financial	Jan-21	account signup

Methodology

Due to the heavy text volume for this project, I opted to use NLP modeling to assess privacy policies, rather than a manual review. I gathered the privacy policies as mentioned above, then utilized a pre-trained NLP library, spaCy, to determine the existence or absence of the below 13 items in each policy. I created a matrix from this, with a no-partial-yes scale (quantified as 0-1-2 for scoring) to represent existence of the language. I used this matrix to do additional comparative analyses. With 13 categories and up to 2 points per category, privacy scores per company could be up to 26 points.

1. Data Collection
    a. Types of data collected
    b. Collection methods
    c. Purpose specification
2. User Rights
    a. Access rights
    b. Deletion rights
    c. Portability options
    d. Opt-out mechanisms
3. Data Sharing
    a. Third-party sharing
    b. International transfers
    c. Service provider requirements
4. Security Measures
    a. Storage practices
    b. Protection methods

c. Breach notification

	Service	types_of_data	collection_methods	purpose_specification	access_rights	deletion_rights	portability	opt_out_mechanisms	third_party_sharing	international_transfers	service_providers	storage_practices	protection_methods	breach_notification	Total Score	Normalized Score	Performance	Word Count
0	discover_privacy.txt	Yes	Yes	Yes	Yes	No	No	Yes	Yes	Yes	No	No	Yes	Yes	18	0.692308	Average	854
1	Meta_privacy.txt	Yes	Yes	Yes	Yes	Yes	No	Yes	Yes	Yes	Yes	Yes	Yes	Yes	24	0.923077	Best Practice	20843
2	microsoft_privacy.txt	Yes	Yes	Yes	Yes	Yes	No	Yes	Yes	No	Yes	Yes	Yes	Partial	21	0.807692	Best Practice	4444
3	netflix_privacy.txt	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	26	1	Best Practice	10494
4	openAI_privacy.txt	Yes	Yes	Yes	Yes	Yes	Partial	Yes	Yes	Yes	Yes	Yes	Yes	Yes	25	0.961538	Best Practice	4277
5	robinhood_privacy.txt	Yes	Yes	Yes	Yes	Yes	No	Yes	Yes	Yes	Yes	Yes	Yes	Yes	24	0.923077	Best Practice	5541
6	spotify_privacy.txt	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	26	1	Best Practice	6347
7	uber_privacy.txt	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	Yes	26	1	Best Practice	8062

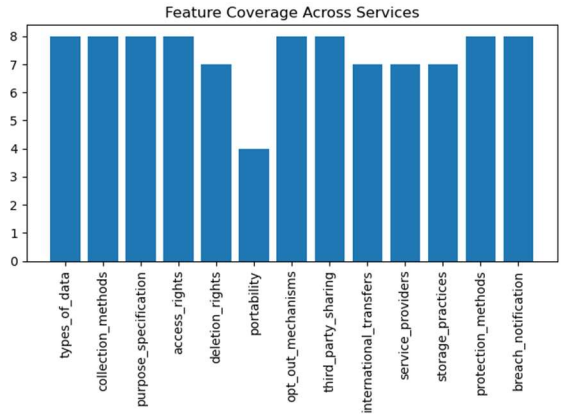
Figure 1: Privacy Matrix

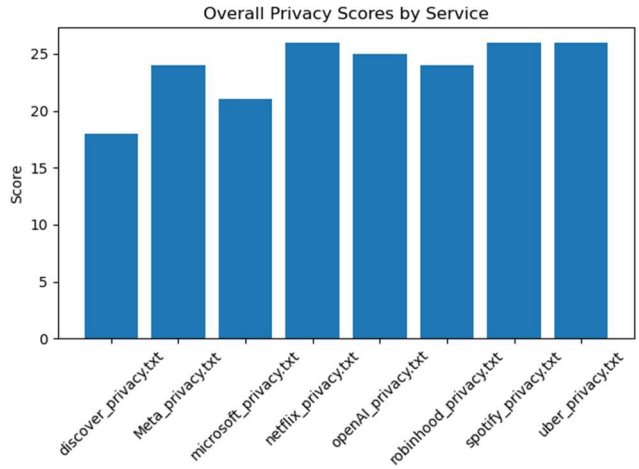
<u>Key findings from comparison</u>

The portability category was significantly lower-scored than the rest, with only 4 of the 8 services mentioning portability. The remaining categories had 7 to 8 services covering those topics in their privacy statements.

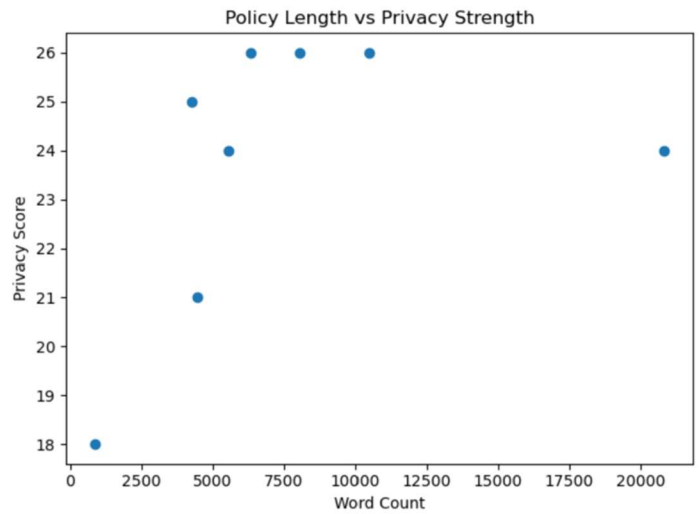
Assessing by service, Discover had the lowest privacy scores, and Microsoft second lowest. Curiously, Discover also had the lowest word-count in their privacy policy (by a large margin), so it seems rather fitting that their privacy score would turn out lower. The policy extracted was specifically for Discover Bank. I hypothesize that its policy may be shorter and less encompassing than others due to the nature of the service not necessarily pertaining to all 13 of these categories. For example, I don't recall seeing ads while I log in to bank, so there are probably less trackers, and it may be just an overall less-invasive type of service.

Overall, the companies surveyed had generally high scores; some even a perfect 26/26. This is not too surprising to me as these are all huge companies with likely airtight legal structures in their privacy policies to ensure they do not fall under scrutiny. It is noteworthy to mention that while some scores may be "perfect", these scores are really just assessing whether there exists language in the policy that pertains to each category. However, they may not fully-capture the meaning or translate to the ideal privacy experience to the user.





	Feature	Count	Category
0	types_of_data	8	Common
1	collection_methods	8	Common
2	purpose_specification	8	Common
3	access_rights	8	Common
4	deletion_rights	7	Moderate
5	portability	4	Moderate
6	opt_out_mechanisms	8	Common
7	third_party_sharing	8	Common
8	international_transfers	7	Moderate
9	service_providers	7	Moderate
10	storage_practices	7	Moderate
11	protection_methods	8	Common
12	breach_notification	8	Common



Regulatory Compliance Assessment

To assess regulatory compliance, I created a scoring-based framework to quantify alignment with major privacy regulations, using extracted policy features as proxies for compliance. The regulations observed were:

- California Consumer Privacy Act (CCPA)
- General Data Protection Regulation (GDPR)
- Virginia Consumer Data Protection Act (VCDPA)

Service	ccpa_access	ccpa_deletion	ccpa_opt_out	ccpa_notice	vcdpa_rights	vcdpa_processing	vcdpa_security	gdpr_rights	gdpr_consent_like	gdpr_transfer	gdpr_security	CCPA_score	VCDPA_score	GDPR_score	CCPA_level	VCDPA_level	GDPR_level
discover_privacy.txt	2	0	2	2	0.666667	2	2	0.666667	2	2	2	1.5	1.555556	1.666667	Strong	Strong	Strong
Meta_privacy.txt	2	2	2	2	1.333333	2	2	1.333333	2	2	2	2	1.777778	1.833333	Strong	Strong	Strong
microsoft_privacy.txt	2	2	2	2	1.333333	2	2	1.333333	2	0	2	2	1.777778	1.333333	Strong	Strong	Moderate
netflix_privacy.txt	2	2	2	2	2	2	2	2	2	2	2	2	2	2	Strong	Strong	Strong
openAI_privacy.txt	2	2	2	2	1.666667	2	2	1.666667	2	2	2	2	1.888889	1.916667	Strong	Strong	Strong
robinhood_privacy.txt	2	2	2	2	1.333333	2	2	1.333333	2	2	2	2	1.777778	1.833333	Strong	Strong	Strong
spotify_privacy.txt	2	2	2	2	2	2	2	2	2	2	2	2	2	2	Strong	Strong	Strong
uber_privacy.txt	2	2	2	2	2	2	2	2	2	2	2	2	2	2	Strong	Strong	Strong

Figure 2: Compliance Matrix

Overall, the services had the strongest compliance with the California Consumer Privacy Act, with only Discover missing marks for language related to deletion. GDPR and VCDPA also had strong scores overall, however GDPR was slightly lower, notably with Microsoft getting no points for language about transfers.

Supplementary Regulatory Compliance Analysis

As a contribution to the collective group project, further analysis on regulatory compliance for 4 of my companies (OpenAI, Discover Bank, Spotify and Microsoft) was performed. It is found in matrix form as a spreadsheet (a separate item in this analysis folder). It differs in scope from the above because the above isn't calibrated with what the group wanted to focus on. While the above section was implemented using SpaCy, depending largely on keyword search, the supplementary analysis was produced largely with the

assistance of an LLM (Claude) which is more intuitive to capture the semantics, nuances, and contexts of the companies' privacy practices. This second round of analysis allows for a more thorough review of the real-world results and thus the ethical implications of this study.

Recommendations for Improvement

As mentioned earlier in this analysis, these matrices and scores are merely assessing whether there exists language in the policy that pertains to each category (or proxy variables for the regulatory compliance). Since my approach was via an NLP model rather than manual review, there could be incorrect results or noise. Moreover, the results may not align with what "ideal" privacy for the user would be. In other words, just because a policy talks about access rights, for example, does not mean the user is guaranteed access rights or that obtaining it may be easy. For this reason, we need not be too impressed with the scoring achieved by these companies.

On the other hand, had I done a manual review, we would also introduce much subjectivity into the analysis, as I would try to score each category without a clear rubric. I did some spot checking to see if the extracted results seemed to align with their categories and the results were reasonable. However, I would recommend further manual validation, specifically with a rubric to ensure scores are consistent. Additionally, I would recommend assessing by a different type of NLP such as hugging face, which is more context-aware and semantically powerful than keyword matching. I would also suggest improving this model by incorporating a larger variety of services, particularly from smaller companies, to broaden my hypothesis of bigger company = more encompassing policies.

As was mentioned in the preceding section, further analysis was performed on some of the companies' regulatory compliance. This utilized an LLM which helped to overcome some of the concerns stated in the prior 2 paragraphs. However, for this type of analysis that relied on group contributions, an improvement for next time would be to calibrate with the group members and broaden the categories that are being observed so that we can more-easily observe broader, over-arching conclusions.

Lessons Learned

One of the central takeaways from this project is that, although natural language processing techniques are effective at identifying patterns and recurring themes in privacy policies, they still fall short when it comes to interpreting the subtleties of dense language. Keyword-based methods often fail to catch subtle context or recognize terms presented indirectly or with nuance. Automated analysis faces a significant challenge when dealing with intricate legal documents, highlighting a wider issue.

Additionally, the project underscored an ethical concern that persists even when privacy policies comply with legal regulations. Despite meeting formal legal standards, the average reader may not understand or even attempt to read them. Their length, technical vocabulary, and legalistic structure create a significant barrier to genuine informed consent.

As a result, many users end up accepting terms without fully reading or understanding them, which raises questions about whether consent can truly be considered meaningful. This gap between regulatory compliance and ethical transparency suggests that satisfying legal requirements alone does not ensure that individuals are adequately informed about how their personal data is collected, used, or shared.